

RAIX — Adequação à LGPD e ao Marco Civil da Internet

Nota Técnica e Evidências de Conformidade

PRIVACIDADE FORTE POR DESIGN & ARQUITETURA ZERO-KNOWLEDGE

Resumo Executivo: O presente documento atesta o posicionamento de conformidade do RAIX em relação à legislação brasileira vigente, especificamente a Lei Geral de Proteção de Dados Pessoais (LGPD — Lei nº 13.709/2018) e o Marco Civil da Internet (MCI — Lei nº 12.965/2014). A arquitetura do RAIX foi projetada desde a concepção sob o paradigma de *Privacy by Design* e *Zero-Knowledge*, mitigando estruturalmente os riscos de exposição de dados. O escopo desta nota técnica restringe-se às jurisdições cobertas pela LGPD e pelo Marco Civil; a adequação a regulações internacionais, como a GDPR, integra o *roadmap* futuro da plataforma.

PARTE I — Lei Geral de Proteção de Dados Pessoais (LGPD)

A. Minimização de Dados (Art. 6º, III)

- **O que a lei exige:** Os dados pessoais tratados devem ser limitados ao mínimo necessário para a realização de suas finalidades.
- **Como o RAIX cumpre:** O RAIX opera sob a premissa de *zero-knowledge*. O servidor não coleta Informações Pessoalmente Identificáveis (PII), tais como e-mail, telefone, nome, CPF ou lista de contatos. Não há processo de cadastro tradicional; a identidade criptográfica do usuário é derivada exclusivamente de um mnemônico local (BIP-39) sob a guarda exclusiva do titular.
- **Evidência:** Arquivo DATA_INVENTORY.md documenta que apenas dados estritos de transporte e metadados de roteamento são retidos pelo tempo máximo de 24 horas. Nenhum dado pessoal é vinculado ou associável ao conteúdo da mensagem.

B. Bases Legais para Tratamento (Art. 7º e Art. 10)

- **O que a lei exige:** O tratamento de dados pessoais somente poderá ser realizado mediante o enquadramento em uma das bases legais previstas (consentimento, obrigação legal, execução de contrato, legítimo interesse, etc.).
- **Como o RAIX cumpre:**
 - **Obrigação Legal (Art. 7º, II):** Guarda de registros de acesso a aplicações de internet por 180 dias, em atendimento ao Art. 15 do Marco Civil da Internet.
 - **Execução de Contrato (Art. 7º, V):** Operações necessárias para a prestação do serviço e faturamento nos planos pagos (profissionais/Premium).
 - **Legítimo Interesse (Art. 10):** Tratamento de dados telemáticos e de diagnóstico estritamente necessários para a segurança, prevenção à fraude e integridade da rede.
- **Evidência:** O Registro das Operações de Tratamento de Dados Pessoais (ROPA) documenta e mapeia exhaustivamente cada operação de tratamento e sua respectiva base legal.

C. Direitos do Titular (Art. 18)

- **O que a lei exige:** O titular tem direito de obter do controlador confirmação, acesso, correção, anonimização, portabilidade, eliminação, informação e revisão de decisões automatizadas.
- **Como o RAIX cumpre:** O atendimento aos direitos dos titulares ocorre mediante o canal formal contato@raixtech.com, com tempo de resposta e execução previsto para até 15 dias corridos.

- **Evidência:** Arquivo DSR_RUNBOOK .md formaliza as rotinas e fluxos: Fluxo A (para dados de transporte sob controle direto da Raix Tech) e Fluxo B (para conteúdo profissional e contatos, onde o profissional/empresa atua como controlador e a Raix Tech como operadora).

D. Encarregado pelo Tratamento de Dados (DPO) (Art. 41)

- **O que a lei exige:** O controlador deverá indicar encarregado pelo tratamento de dados pessoais, com identidade e informações de contato divulgadas de forma clara e objetiva.
- **Como o RAIX cumpre:** O contato formal contato@raixtech.com está publicamente designado como o canal direto de comunicação com o Encarregado (DPO).
- **Evidência:** Expressamente designado e divulgado na Política de Privacidade (PP) e no ROPA.

E. Segurança da Informação (Art. 46)

- **O que a lei exige:** Adoção de medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas.
- **Como o RAIX cumpre:** A criptografia de ponta-a-ponta (E2E) é o pilar da plataforma. Utiliza cifra AES-256-GCM com uma Data Encryption Key (DEK) única por mensagem. O servidor atua "cego" e o ciclo de vida da informação abrange o expurgo criptográfico (*crypto-shredding*), o padrão *vanish-after-read* (autodestruição) e a proteção por chaves respaldadas por hardware local.
- **Evidência:** Homologação E2E validada mediante três provas criptográficas de produção: Prova de Servidor Cego, Prova de Round-Trip Real e Prova de Isolamento Adversarial, atestando a Cadeia de Custódia ininterrupta de ponta a ponta.

F. Responsabilização e Prestação de Contas (Art. 6º, X e Art. 37)

- **O que a lei exige:** Demonstração da adoção de medidas eficazes para o cumprimento da lei e manutenção de registros de tratamento.
- **Como o RAIX cumpre:** O RAIX adota governança proativa e transparência operacional contínua por meio de extensa documentação pública e auditorável.
- **Evidência:** Documentos publicados (Política de Privacidade [PP], Termos de Uso [ToU], Data Processing Agreement [DPA] e ROPA), inventário de dados, *runbook* de Data Subject Requests (DSR) e rotinas contínuas de *health-check* operacional.

G. Operadores e Suboperadores (Art. 39)

- **O que a lei exige:** Os operadores devem realizar o tratamento segundo instruções fornecidas pelo controlador, com garantias de conformidade.
- **Como o RAIX cumpre:** As relações com provedores de infraestrutura (suboperadores como Google Cloud e Firebase) são formalmente amparadas. Pela natureza do *zero-knowledge*, o conteúdo permanece ilegível (cifrado) mesmo na infraestrutura do suboperador.
- **Evidência:** Existência de Data Processing Agreement (DPA) aplicável e arquitetura que impossibilita a extração de texto claro na camada de infraestrutura.

H. Comunicação de Incidentes de Segurança (Art. 48)

- **O que a lei exige:** O controlador deve comunicar à Autoridade Nacional (ANPD) e ao titular a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante.
- **Como o RAIX cumpre:** O princípio *zero-knowledge* reduz materialmente o risco a um potencial de impacto residual, dado que vazamentos de bancos de dados da plataforma não expõem PII legíveis ou conteúdo de mensagens.

- **Evidência:** Política de Resposta a Incidentes documentada, estipulando notificação à ANPD no prazo máximo de 3 (três) dias úteis nos casos aplicáveis, conforme Resolução CD/ANPD nº 15/2024.

PARTE II — Marco Civil da Internet (MCI)

A. Guarda de Registros de Acesso a Aplicações (Art. 15)

- **O que a lei exige:** O provedor de aplicações de internet deve manter os respectivos registros de acesso de forma sigilosa, em ambiente controlado e seguro, pelo prazo de 6 (seis) meses.
- **Como o RAIX cumpre:** O sistema retém `accessLogs` restritos, isolados logicamente da camada de aplicação de mensagens. Os campos capturados restringem-se ao necessário para transporte telemático: IP de origem, timestamp em UTC, porta lógica e função (*function*). Não há associação destes dados ao conteúdo, chaves de criptografia ou mnemônico do usuário.
- **Evidência:** Mecanismo arquitetural de expurgo por *Time-to-Live* (TTL) associado a *shredder*, que oblitera irrecuperavelmente os *logs* isolados ao atingir o prazo de 180 dias.

B. Disponibilização Judicial de Registros (Art. 10 e Art. 13)

- **O que a lei exige:** O fornecimento de registros de acesso deve ser feito mediante ordem judicial, respeitando a privacidade e a proteção de dados.
- **Como o RAIX cumpre:** A empresa adota uma postura de estrita cooperação com as autoridades legais. Cumpre-se a entrega daquilo que materialmente existe (os logs isolados de conexão telemática).
- **Evidência:** Por construção arquitetônica da plataforma, o RAIX não custodia o conteúdo legível das mensagens nem as chaves privadas de decifração. Consequentemente, não há possibilidade material de entrega interceptada de conteúdo, limitando a resposta legal ao escopo que a arquitetura matematicamente retém.

C. Sigilo e Privacidade das Comunicações (Art. 7º e Art. 10)

- **O que a lei exige:** Garantia da inviolabilidade e do sigilo do fluxo das comunicações pela internet, salvo por ordem judicial aplicável.
- **Como o RAIX cumpre:** Por desenho tecnológico de criptografia E2E validada, o RAIX não intercepta, não inspeciona, não cifra e não decifra em trânsito o conteúdo das comunicações entre usuários.
- **Evidência:** A arquitetura *zero-knowledge* garante empiricamente que a plataforma opera como duto cego, sendo os metadados gerados tratados em estrita observância ao Marco Civil.

PARTE III — Disposições Finais

Declaração de Escopo e Limitações: A arquitetura, processos e políticas delineados neste documento refletem a conformidade formal da plataforma RAIX exclusivamente para o território e legislação da República Federativa do Brasil (LGPD e Marco Civil da Internet). Não se atesta ou reivindica, nesta versão, a adequação plena a frameworks regulatórios estrangeiros ou extraterritoriais (tais como a GDPR europeia, CCPA ou congêneres), cuja adequação está programada no *roadmap* de expansão futura.

Trilha de Auditoria: O presente ateste técnico está fundamentado em artefatos reais de sistema e operacionais, englobando as políticas vigentes no domínio `raixtech.com`, o ROPA estabelecido, os fluxos do `DSR_RUNBOOK.md`, as matrizes do `DATA_INVENTORY.md`, as 3 provas de produção da homologação End-to-End, a retenção restrita de `accessLogs` com expurgo em 180 dias e as varreduras recorrentes de integridade (*health-check*).

(Documento gerado para fins de Due Diligence, Investimentos e Conformidade Jurídica)